

Customer-Facing Compliance Report

Framework: IEC 62443 - Industrial Automation and Control Systems Security

Primary audience: Industrial, manufacturing, energy, utilities, transportation, and pharmaceutical operators and integrators applying IEC 62443 zones and conduits architecture.

CSW positioning: IT-side workload segmentation that aligns with zones and conduits architecture; the OT device-layer SR controls are addressed by an OT-native product (Cyber Vision, Claroty, Nozomi).

Framework Version Note

IEC 62443 is a multi-part series (e.g. 62443-2-1 for IACS security programmes, 62443-3-2 for zones and conduits / risk assessment, 62443-3-3 for system security requirements, 62443-4-2 for component requirements). This report focuses on the zones-and-conduits and system-security-requirement themes; cite the specific part and edition relevant to the customer's certification scope.

CSW UI Navigation Note

Cisco does not yet publish framework-specific CSW UI navigation for this standard; framework-specific navigation is on the product roadmap. This report references CSW *capabilities* and the *evidence artifacts* they produce. The technical runbook (CSW-IEC-62443-Technical-Runbook.md) in this folder contains the deeper engineering detail.

Executive Summary

Cisco Secure Workload (CSW) supports a defined subset of this framework. The strongest customer story is not that CSW "certifies" compliance; it is that CSW turns workload communication and inventory into evidence that the customer, the customer's compliance team, and the customer's assessor can review. This report describes which framework topics CSW supports, which it does not, what evidence artifacts CSW produces, and how often the customer should collect them. CSW does not replace the customer's governance, policy, or assessor judgement, and this report is not a control attestation.

Suggested CSW Scope Pattern

“

IEC-62443

??? IT-Side-Zones (Enterprise-Zone, Operations-Zone-IT-Side)

??? IT-OT-DMZ-IT-Side (Historians, Engineering-Workstations, Jump-Hosts, Patch-Servers, Asset-Servers)

??? Conduits (observed IT-side endpoints of every IT-OT conduit)

??? OT-Side-Zones (NOT instrumented; observed via conduit endpoints)

This scope pattern should be validated with the customer's architecture, application owners, compliance team, and assessor before it is used for formal evidence.

In Scope for CSW Evidence

- ? Zone definition (IT side) and IT-side conduit endpoints
- ? Foundational Requirement-aligned themes on the IT side: Identification and Authentication Control (FR1), Use Control (FR2), System Integrity / monitoring (FR3 / FR6), Data Confidentiality (detection, FR4), Restricted Data Flow (FR5)
- ? Network architecture evidence on the IT side
- ? Vulnerability management with reachability context
- ? Incident response - IT-side forensic input

Out of Scope (Must Be Evidenced by Other Controls / Tools / Processes)

- ? Component-level (FR / SR) requirements on OT devices (PLC, RTU, IED, HMI)
- ? OT protocol inspection and OT change management
- ? Physical security and personnel controls
- ? Cryptography enforcement on OT links
- ? Safety system controls

Framework Topic ? CSW Capability Map

Framework topic	CSW capability	Evidence artifact
Zone and conduit architecture (IT side)	Scope architecture mirroring zones; policy workspace as conduit allowlist	Workspace snapshot + observed conduit flow report
Restricted Data Flow (FR5, IT side)	Workload-to-workload allowlist between zones; cross-zone deny enforcement	Policy workspace + cross-zone violation log
System Integrity / Monitoring (FR3 / FR6)	Continuous flow + process telemetry; alerts on unauthorised conduit flow	Alert and anomaly log scoped to IEC-62443
Use Control (FR2) workload layer	Policy workspace + enforcement / violation log	Workload-to-workload use-control evidence
Data Confidentiality (FR4) detection	Plaintext-flow detection on regulated paths	Detection input only
Vulnerability handling	Reachability-weighted CVE on IT-side zone members	Prioritised remediation list with compensating-control register
Incident response (IT side)	Forensic flow + process telemetry	Investigation pack with timeline and impact scope

Evidence Collection Approach

The table below describes per-topic evidence collection - what to collect, the CSW source area, and a suggested cadence. The cadence should be tuned to the customer's audit cycle, regulatory cadence, and risk appetite.

Topic	What to collect	CSW source	Suggested cadence
Zone inventory (IT side)	Workloads grouped by zone and conduit endpoint	Inventory + scope membership export with iec62443_zone label	Monthly
Conduit evidence	Observed and approved IT-side conduit flows	ADM workspace export + policy workspace export	Quarterly
Cross-zone deny evidence	Cross-zone violation log	Policy analysis output	Continuous; reviewed quarterly
Vulnerability + reachability	CVE list weighted by reach into OT-side zones	Vulnerability report scoped to IEC-62443	Monthly
Incident sample	One representative IT-side incident timeline	Flow + process search	Per incident; one representative sample per audit cycle

POV / Workshop Approach

1. Confirm the framework version and assessment cycle with the customer's compliance team.
2. Select one business service, regulated boundary, or critical workload group to start with; do not attempt to instrument the entire estate in the POV.
3. Validate workload coverage and install sensors or configure supported connectors. Document the cannot-instrument register; this is itself evidence.
4. Apply labels for application, environment, owner, data class, criticality, compliance scope, and any framework-specific tags (e.g. tenant, prototype, isa_level, np, cui, ephi').
5. Observe flows over a representative business window. Minimum two weeks; longer if the customer has month-end, quarterly, or seasonal cycles relevant to the scope.
6. Use ADM to generate a candidate policy. Review with the application owner. Run in Simulation mode for at least two weeks before any enforcement.
7. Package inventory, scope, flows, policy, exceptions, and known gaps as the evidence output. Cross-reference this report's evidence collection table with the customer's existing audit work-papers.

Boundaries and Complementary Controls

CSW does not certify against IEC 62443, parse OT protocols, enforce SR controls on OT components, manage OT change windows, or replace an OT-native product (Cyber Vision, Clarity, Nozomi, Dragos) for OT device discovery and protocol inspection.

Assessor / Auditor Caveat

CSW provides technical evidence inputs. The customer's qualified assessor, auditor, certifying body, or regulator determines compliance status. Validate all framework-topic mappings, control IDs, paragraph references, and section numbers in this report against the current official framework text. If the customer is being assessed against a version other than the one referenced in the framework version note above, revalidate before use.

Disclaimer

This report is for informational and planning purposes. It is not legal, regulatory, audit,

or certification advice. Validate all mappings against the current official framework text, the customer's environment, and qualified compliance, legal, and audit professionals.